

Incident Report — Home Cyber Range Attack Simulation

Prepared by: Sanchit Kaushik **Environment:** Isolated virtual lab (Host-Only network, 192.168.128.0/24) **Date of activity:** July 20, 2026 through August 7, 2026

1. Executive Summary

A simulated attack was carried out against two intentionally vulnerable targets (Metasploitable2 and a DVWA web application) from an attacker host (Kali Linux), within an isolated lab network. All activity was monitored and logged by a dedicated defensive host running Suricata (IDS) and Splunk (SIEM). This report documents the reconnaissance, exploitation, and detection phases, along with recommended remediations for each vulnerability exploited.

2. Lab Environment

Host	Role	IP Address	OS
Kali Linux	Attacker	192.168.128.4	Kali Rolling (ARM64)
Metasploitable2	Target — OS/service exploitation	192.168.128.2	Ubuntu 8.04 (intentionally vulnerable)
DVWA (Ubuntu Server)	Target — web application exploitation	192.168.128.6	Ubuntu Server 26.04
soc-monitor	Defender — IDS/SIEM	192.168.128.8	Ubuntu Server 26.04 (x86_64)

Tools used: Nmap, Burp Suite Community, Metasploit Framework, Suricata, Splunk Enterprise, tshark/Wireshark.

3. Timeline

Time	Event
13:20	Nmap network sweep (<code>nmap -sn 192.168.128.0/24</code>) — enumerated live hosts
13:22	Nmap service/version scan against Metasploitable2
13:35	Burp Suite proxy configured; SQL Injection attempted against DVWA
13:37	SQL Injection payload <code>1' OR '1'='1</code> succeeded — full user table dumped
13:46	Metasploit <code>exploit/multi/samba/usermap_script</code> executed against Metasploitable2
14:03	Root shell obtained on Metasploitable2 via Samba usermap_script (CVE-2007-2447)
14:09	Suricata alerts reviewed on soc-monitor confirming detection of the above
14:20	Alerts ingested into Splunk and confirmed searchable

4. Attack Details

4.1 Reconnaissance (Nmap)

- Performed a host discovery sweep and service/version scans against lab targets.
- Identified Metasploitable2 running vulnerable, outdated services (vsftpd 2.3.4, Samba).
- **Tool:** Nmap 7.99

4.2 Web Application Exploitation (Burp Suite + SQL Injection)

- **Target:** DVWA, SQL Injection module (security level: Low)
- **Vulnerability:** Unsanitized user input concatenated directly into a SQL query.
- **Payload:** `1' OR '1'='1`
- **Result:** The injected payload altered the query's WHERE clause to always evaluate true, causing the application to return **all** user records instead of the single requested record — a full data exposure.

- **Evidence:** Captured in Burp Suite's Proxy → HTTP History; request/response pair showing the payload and the resulting multi-row dump.

4.3 Remote Exploitation (Metasploit)

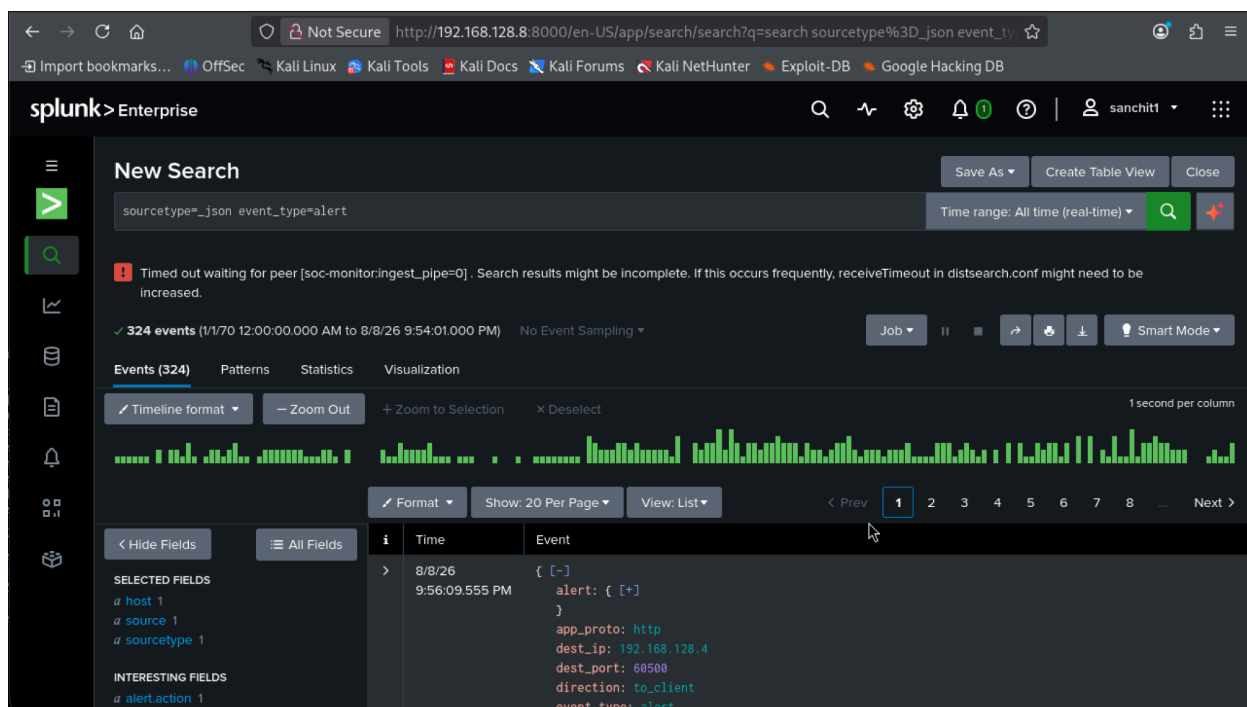
- **Target:** Metasploitable2
 - **Vulnerability exploited:** Samba "username map script" command injection (CVE-2007-2447)
 - **Module:** `exploit/multi/samba/usermap_script`
 - **Result:** Obtained a remote command shell with **root** privileges on the target — full system compromise.
 - **Evidence:** `whoami` returned `root`; `id / uname -a` output captured for verification.
 - *(Note: initial attempts targeted the vsftpd 2.3.4 backdoor (CVE-2011-2523) but were unsuccessful due to the exploit's known timing/cooldown constraints on the backdoor listener; the Samba vector was used as a reliable alternative.)*
-

5. Detection & Analysis

- **Suricata**, running on the soc-monitor host and watching the lab's Host-Only interface in promiscuous mode, logged the reconnaissance and exploitation traffic in `/var/log/suricata/eve.json`.
- Alert-type events were confirmed for traffic originating from the attacker (192.168.128.4), including at least one HTTP-related alert tied to the DVWA exploitation activity.
- **Splunk**, configured to ingest Suricata's `eve.json` as a JSON-sourced file input, made this data searchable. A search of `sourcetype=_json event_type=alert` returned 43 matching events across the monitored period, confirming successful end-to-end detection pipeline: attack → network capture → IDS alert → SIEM visibility.

Sample detection search used:

`sourcetype=_json event_type=alert (src_ip=192.168.128.4 OR dest_ip=192.168.128.4)`



6. Indicators of Compromise (IOCs)

Indicator	Value
Attacker IP	192.168.128.4
Exploited service (Metasploitable2)	Samba (usermap_script), port 139/445
Exploited application (DVWA)	SQL Injection endpoint, <code>/dvwa/vulnerabilities/sqli/</code>
SQLi payload	<code>1' OR '1'='1</code>
CVE references	CVE-2007-2447 (Samba usermap_script), CVE-2011-2523 (vsftpd 2.3.4 backdoor, attempted)

7. Remediation Recommendations

1. **Samba usermap_script vulnerability:** Upgrade Samba to a patched version; disable the `username map script` configuration option unless explicitly required.

2. **vsftpd backdoor:** Upgrade to a non-backdoored vsftpd release; verify package integrity via checksums/signatures for any FTP service in production.
 3. **SQL Injection (DVWA):** Use parameterized queries / prepared statements instead of string concatenation for all database queries involving user input. Apply input validation and least-privilege database accounts.
 4. **General:** Network segmentation (as demonstrated in this lab) limits blast radius; production environments should apply similar isolation between exposed services and sensitive systems, combined with active IDS/SIEM monitoring as implemented here.
-

8. Conclusion

This exercise demonstrated a complete attack lifecycle — reconnaissance, web application exploitation, and remote system compromise — against intentionally vulnerable targets in an isolated lab, with all activity captured and made searchable through a working IDS/SIEM detection pipeline. The exercise reinforced both offensive techniques (Nmap, Burp Suite, Metasploit) and defensive/analytical skills (Suricata rule-based detection, Splunk log ingestion and search).